VENDOR RISK ASSESSMENT

Third-Party SaaS Payroll Tool Evaluation

Prepared under NIST Cybersecurity Framework 2.0

Client	Meridian Financial Group
Vendor Evaluated	PayStream Pro (SaaS Payroll Platform)
Engagement Type	Third-Party Vendor Risk Assessment
Framework	NIST Cybersecurity Framework 2.0
Assessment Date	March 14, 2026
Classification	CONFIDENTIAL — Internal Use Only
Prepared by	Christopher Tolbert, GRC Analyst
Distribution	CISO, VP of Finance, Head of IT

This document is intended solely for the use of Meridian Financial Group's executive leadership and IT security team. Distribution outside the named recipients requires written authorization from the CISO.

1. Executive Summary

Meridian Financial Group is evaluating PayStream Pro, a cloud-based SaaS payroll platform, as a replacement for its legacy on-premises payroll system. This assessment was commissioned to identify the cybersecurity and compliance risks associated with adopting a third-party vendor that will have access to sensitive employee and financial data.

The assessment was conducted using the NIST Cybersecurity Framework (CSF) 2.0 as the governing methodology, evaluating risk across the six core functions: Govern, Identify, Protect, Detect, Respond, and Recover. A total of seven threat scenarios were analyzed across four primary asset categories.

Key Findings at a Glance

- **Overall Residual Risk Rating:** HIGH — adoption is not recommended without remediation of critical gaps
- 3 of 7 threat scenarios rated HIGH risk; 3 rated MEDIUM; 1 rated LOW
- Critical gaps identified in data encryption, access control, and vendor contractual obligations
- Regulatory exposure: PCI DSS v4.0, SOX Section 404, and GLBA Safeguards Rule applicable
- 12 controls recommended; 4 designated as immediate pre-adoption requirements

Meridian's risk appetite, as defined in the 2025 Information Security Policy, does not permit acceptance of HIGH-rated vendor risks without compensating controls. The CISO is advised to condition contract execution on resolution of the four pre-adoption requirements identified in Section 6.

2. Scope & Methodology

2.1 Scope

This assessment covers the evaluation of PayStream Pro as a third-party SaaS payroll platform. In scope:

- All data flows between Meridian systems and the PayStream Pro platform
- PayStream Pro's security controls, policies, and compliance posture
- Meridian's internal controls governing vendor onboarding and access management
- Employee PII, payroll data, and banking/direct deposit information handled by the platform

2.2 Methodology

The assessment follows the NIST Cybersecurity Framework (CSF) 2.0 structure, mapping risk findings to the six core functions:

CSF Function	Focus Area	What We Evaluated
GOVERN (GV)	Policies & Oversight	Vendor management policies, contractual security requirements, risk acceptance process
IDENTIFY (ID)	Asset & Risk Inventory	Data assets at risk, third-party dependencies, threat and vulnerability analysis
PROTECT (PR)	Safeguards	Encryption standards, access controls, data handling procedures, employee training
DETECT (DE)	Monitoring	Logging capabilities, anomaly detection, security event alerting
RESPOND (RS)	Incident Response	Breach notification SLAs, incident response coordination, contractual obligations
RECOVER (RC)	Resilience	Backup procedures, RTO/RPO commitments, business continuity provisions

Evidence gathered through: vendor security questionnaire (VSQ), review of PayStream Pro's SOC 2 Type II report (2024), contractual terms review, and internal interviews with Meridian's HR and IT teams.

3. Assets at Risk

The following asset categories are directly implicated by PayStream Pro's access and data processing requirements. Asset criticality is rated relative to Meridian's business continuity and regulatory obligations.

#	Asset Category	Data Types Included	Regulatory Relevance	Criticality
1	**Employee PII**	Full name, SSN, DOB, home address, phone, email	GLBA, State Privacy Laws	HIGH
2	**Payroll & Compensation Data**	Salary, bonuses, direct deposit routing/account numbers, W-2 data	SOX §404, GLBA	HIGH
3	**Authentication Credentials**	Meridian employee usernames, passwords (hashed), MFA tokens	ISO 27001, NIST SP 800-63	HIGH
4	**Financial Account Data**	Employee bank routing/account numbers for direct deposit	PCI DSS v4.0 (ancillary)	HIGH
5	**HR System Integration Data**	API keys and tokens for HRIS system (Workday) integration	Internal Data Classification	MEDIUM
6	**Audit Logs & Reports**	Payroll run logs, change history, admin activity logs	SOX §404, Internal Audit	MEDIUM
7	**Meridian Network Endpoints**	Computers/devices accessing PayStream Pro via browser or API	Internal Security Policy	LOW

4. Threat Scenarios

Seven threat scenarios were analyzed based on asset exposure, historical vendor breach data (VCDB 2023-2025), and Meridian's industry peer incidents. Each scenario is mapped to the relevant NIST CSF function where the primary control gap exists.

#	Threat Scenario	Description	Threat Actor	CSF Function	Risk
1	**Data Breach via Vendor Platform**	Attacker exploits vulnerability in PayStream Pro's cloud infrastructure, exfiltrating employee SSNs and banking data	External / Cybercriminal	IDENTIFY (ID)	HIGH
2	**Unauthorized Access — Insider**	Meridian HR admin with excessive permissions exports full employee payroll data without authorization	Insider / Malicious Employee	PROTECT (PR)	HIGH
3	**API Integration Compromise**	Attackers intercept or replay API tokens used in the Workday ↔ PayStream Pro integration to manipulate payroll transactions	External / APT	PROTECT (PR)	HIGH
4	**Ransomware via Vendor Access**	Threat actor uses PayStream Pro admin access as an entry point to pivot into Meridian's network and deploy ransomware	External / Ransomware Group	RESPOND (RS)	MEDIUM
5	**Business Email Compromise (BEC)**	Attacker spoofs PayStream Pro support and tricks HR staff into changing direct deposit routing numbers for executives	External / Social Engineer	PROTECT (PR)	MEDIUM
6	**Vendor Data Retention Violation**	After contract termination, PayStream Pro retains copies of Meridian employee data beyond contractually agreed deletion windows	Vendor / Non-compliance	GOVERN (GV)	MEDIUM
7	**Service Outage — Payroll Delay**	PayStream Pro experiences a multi-day outage during payroll processing window, causing missed payroll obligations	Vendor / Operational	RECOVER (RC)	LOW

5. Vulnerability Gaps

The following gaps were identified through review of PayStream Pro's SOC 2 Type II report, vendor security questionnaire responses, and contractual terms. Each gap is mapped to the NIST CSF function where the control deficiency exists.

#	Gap Area	Finding	CSF Mapping	Severity
1	**Encryption at Rest**	PayStream Pro does not encrypt employee PII fields (SSN, banking data) at the field level — only disk-level encryption is applied. Field-level encryption is required under Meridian's data classification policy.	PROTECT — PR.DS-1	HIGH
2	**Access Control / RBAC**	Vendor does not support attribute-based or role-based access that maps to Meridian's internal job functions. All HR users receive identical permission sets with no least-privilege enforcement.	PROTECT — PR.AC-3	HIGH
3	**API Security**	API tokens for the Workday integration do not expire and are not rotated automatically. No IP allowlisting is configured. Token compromise would grant persistent access to payroll data with no detection capability.	PROTECT — PR.AC-4	HIGH
4	**Contractual Data Rights**	Current vendor MSA does not include a data deletion clause. Meridian has no contractual mechanism to enforce post-termination data destruction or audit compliance with retention limits.	GOVERN — GV.SC-4	MEDIUM
5	**Incident Notification**	Vendor SLA for breach notification is 72 hours — which meets GDPR minimums but not Meridian's internal policy of 24 hours for systems handling Tier 1 data. No financial penalty clause for late notification.	RESPOND — RS.CO-3	MEDIUM
6	**Security Logging**	PayStream Pro does not provide Meridian with a direct feed of admin activity logs. Logs are available only on request (5-business-day SLA), making real-time detection of insider threats or unauthorized access effectively impossible.	DETECT — DE.AE-1	MEDIUM
7	**Availability / RTO**	Vendor SLA guarantees 99.5% uptime (43.8 hrs downtime/year permitted). No defined RTO for	RECOVER — RC.RP-1	LOW

		payroll processing specifically. A 48-hour outage during a payroll window could violate federal wage payment deadlines.		

6. Risk Register — Likelihood × Impact Analysis

Risks are scored using a 1–5 scale for Likelihood and Impact. Residual Risk = Likelihood × Impact (1–25 scale), translated to LOW / MEDIUM / HIGH ratings. Ratings reflect Meridian's current control posture without additional vendor remediation.

LOW (1–6)	MEDIUM (7–14)	HIGH (15–25)
Monitor; accept within current risk appetite	Remediate within 90 days; compensating control required	Remediate before adoption; escalate to CISO immediately

#	Risk	Likelihood (1–5)	Impact (1–5)	Score	Rating	Pre-Adoption Required?
1	Data breach via vendor platform	4	5	**20**	HIGH	YES — encryption must be remediated
2	Insider unauthorized data export	4	4	**16**	HIGH	YES — RBAC must be implemented
3	API token compromise	3	5	**15**	HIGH	YES — token rotation required
4	Ransomware via vendor pivot	2	5	**10**	MEDIUM	YES — IR coordination plan required
5	Business Email Compromise (BEC)	3	3	**9**	MEDIUM	No — awareness training sufficient
6	Data retention violation	3	3	**9**	MEDIUM	No — address in contract negotiation
7	Service outage / payroll delay	2	3	**6**	LOW	No — monitor SLA compliance

7. Recommended Controls

Controls are prioritized in three tiers. Tier 1 items are pre-adoption requirements — contract execution should be conditioned on vendor confirmation of these items. Tiers 2 and 3 should be implemented within 30 and 90 days of adoption, respectively.

Tier 1 — Pre-Adoption Requirements (Block contract execution until resolved)

#	Control	Description	NIST CSF Mapping	Addresses Risk #
T1-1	**Field-Level Encryption**	Require PayStream Pro to implement AES-256 field-level encryption for SSN, bank account, and compensation fields at rest. Validate via updated SOC 2 or penetration test attestation.	PROTECT — PR.DS-1	1
T1-2	**Role-Based Access Control**	Require PayStream Pro to implement configurable RBAC aligned to Meridian's HR role taxonomy. Meridian to define at minimum: Read-Only, Processor, and Admin roles with documented access matrices.	PROTECT — PR.AC-3	2
T1-3	**API Token Rotation Policy**	Require API tokens to expire after 90 days with automated rotation. Implement IP allowlisting for all API calls originating from Meridian systems. Conduct API security review before go-live.	PROTECT — PR.AC-4	3
T1-4	**Incident Response SLA Clause**	Negotiate contract to include 24-hour breach notification, financial penalties for non-compliance, and joint tabletop exercise requirement within 60 days of go-live.	RESPOND — RS.CO-3	4

Tier 2 — Implement Within 30 Days of Adoption

#	Control	Description	NIST CSF Mapping	Addresses Risk #
T2-1	**Real-Time Log Integration**	Negotiate SIEM log feed from PayStream Pro covering admin activity, login events, and data exports. Integrate with Meridian's existing SIEM within 30 days of go-live.	DETECT — DE.AE-1	2, 4
T2-2	**Data Deletion Contractual Clause**	Amend MSA to include post-termination data destruction requirement (30-day window), annual certification of compliance, and right-to-audit provisions for Meridian.	GOVERN — GV.SC-4	6

T2-3	**BEC Awareness Training**	Deliver targeted phishing/BEC awareness session to all HR staff processing payroll changes. Include scenario: vendor impersonation requesting direct deposit changes.	PROTECT — PR.AT-1	5

Tier 3 — Implement Within 90 Days of Adoption

#	Control	Description	NIST CSF Mapping	Addresses Risk #
T3-1	**Vendor Availability SLA Review**	Negotiate defined RTO of ≤4 hours for payroll processing functions. Identify manual payroll contingency procedure if SaaS platform is unavailable during payroll window.	RECOVER — RC.RP-1	7
T3-2	**Annual Vendor Reassessment**	Schedule annual vendor risk reassessment for PayStream Pro. Trigger reassessment immediately upon any security incident, ownership change, or material platform update.	GOVERN — GV.SC-7	1–7
T3-3	**Privileged Access Review**	Conduct semi-annual review of all Meridian user accounts in PayStream Pro. Automatically revoke access for terminated employees within 24 hours via HRIS integration.	PROTECT — PR.AC-1	2
T3-4	**Tabletop Exercise**	Conduct annual tabletop exercise simulating a payroll data breach originating from the PayStream Pro platform. Validate IR coordination procedures with vendor.	RESPOND — RS.IM-1	1, 4
T3-5	**SOC 2 Continuous Monitoring**	Require annual delivery of PayStream Pro's SOC 2 Type II report. Establish process for Meridian IT to review and flag any new exceptions or control deficiencies.	GOVERN — GV.SC-9	1–3

8. Appendix — Regulatory Reference Summary

The following regulatory frameworks are applicable to Meridian Financial Group's handling of payroll and employee data. Gaps identified in this assessment may trigger reporting obligations or expose Meridian to regulatory penalties.

Regulation	Governing Body	Applicable Data	Risk of Non-Compliance
GLBA Safeguards Rule	FTC / OCC	Customer and employee financial data	Up to $100K/day in fines; reputational harm
SOX §404	SEC / PCAOB	Financial reporting, payroll controls	Criminal liability for executives; audit failure
PCI DSS v4.0	PCI Security Standards Council	Payment card / direct deposit data	Card processing suspension; per-incident fines
State Privacy Laws (CA CPRA)	CA AG / CPPA	Employee PII for CA-based employees	Up to $7,500 per intentional violation
NIST CSF 2.0	NIST (voluntary)	All cybersecurity risk domains	Not legally binding; benchmarked in contracts

Document Control

Version: 1.0 — Initial Release

Status: DRAFT — Pending CISO Review

Next Review: September 14, 2026 (or upon material change to vendor platform)

Owner: Christopher Tolbert, GRC Analyst